LLM Application Security Policy

1. Prompt injection (OWASP LLM01)

Direct prompt injection is when a user writes instructions intended to override the system's rules. Indirect prompt injection is when those instructions are hidden inside content the system reads, such as a PDF or web page.

Every user query passes through the input sanitization wrapper before retrieval. Blocked requests are logged with the names of the rules they matched.

2. Document ingestion controls

Every PDF chunk is scanned for injection patterns before it is indexed. Flagged chunks are quarantined: they are stored for audit but excluded from all search results.

The security team reviews the quarantine list every Monday.

3. Data handling

Customer personal data must never be placed in prompts. API keys are stored only in environment variables or a secret manager and are rotated every 90 days.